

Phishing Email Detection & Awareness Report

CYBERSECURITY TASK #2

ZAMEER HASSAN

June 2026

Table of Contents

1. Executive Summary:	2
2. Objectives	3
3. Methodology	3
4. Tools Used	3
5. Common Phishing Indicators	4
6. Phishing email analysis	5
6.1 PayPal Phishing Email.....	5
6.2: FedEx Delivery Scam.....	9
6.3 CEO Fraud Email (Business Email Compromise).....	13
7. Risk Assessment	15
7.1 Risk Assessment Summary Table.....	15
7.2 Individual Risk Analysis.....	16
7.3 Risk Factors shared by all samples.....	16
7.4 Overall Risk Rating	16
8. User Awareness Guidelines	17
8.1 Email Safety Guidelines	17
8.2 Specific Guidelines Based on Analysed Samples	17
8.3 Do's and Don'ts Summary.....	18
9. Recommendations	18
9.1 Technical Recommendations	18
9.2 Procedural Recommendations.....	19
9.3 Awareness and Training Recommendations	19
9.4 Priority Recommendation	19
10. Conclusion	20
References	21

1. Executive Summary

Phishing is one of today's most widespread and destructive cyber threats that can be exploited not only by poor technical defences, but also by the absence of user awareness. This report includes an in-depth analysis of three examples of phishing emails, each from a different type of attack: credential theft, personal data harvesting, and Business Email Compromise (BEC).

PayPal Account Limitation Scam was a spoofed sender domain email that claimed to require verification to limit the account. PayPal Account Limitation Scam was a spoofed sender domain email that claimed to need verification to limit the account. The second sample, a FedEx Delivery Scam, stole personal details from the user claiming to be a trusted courier service due to an incorrect delivery address. The third email, a CEO Fraud email, was significantly different in its attack methodology and was completely based on social engineering and executive impersonation to get an employee to make a purchase with gift vouchers without the traditional financial approval processes.

All emails were manually analysed and tested with various tools such as MXToolbox, Whois, VirusTotal and URLScan.io to evaluate the sender's legitimacy, reputation of the domain and the activity of the infrastructure. The investigation found that all three samples contained several known phishing characteristics such as unsolicited/suspicious sender addresses, generic greetings, urgent or threatening language, and requests for confidential information or for unauthorized financial transactions.

The risk assessment determined both the PayPal and the CEO Fraud samples to be Critical threats because they had the potential to cause a financial loss, and the FedEx sample to be a High threat because the focus was on the exposure of personal information. Notably, the sample of CEO Fraud revealed one of the key findings of this report; not all phishing attacks are technically deceptive. The advantage of link-based attacks is that they can be detected by domain and URL analysis, but Business Email Compromise attacks call for a different line of defence based on procedural verification and awareness of humans.

This report makes recommendations based on these findings, which include a layered defence approach focusing on technical controls including the enforcement of SPF, DKIM and DMARC, mandatory multi-factor authentication and procedural safeguards such as out-of-band verification for financial requests. Another important point is ongoing user awareness training with the help of practical examples (the kind of examples that have been analysed in this report), so that individuals and organisations can identify and fend off new phishing methods.

At the end of the day, this report proves that the user base is the first and foremost weak link in the cyber security chain, and therefore, the most important part of phishing defence will be to ensure they are aware of and diligent about maintaining vigilance.

2. Objectives

The aim of the present report is to study a set of phishing samples and see what are the common characteristics of phishing emails that are used by attackers to trick their users. The report will attempt to categorize phishing attacks, estimate the impact of these attacks, and offer suggestions to enhance awareness of cyber security. The results will assist users identify phishing attempts and minimize their risk of falling victim to cyberattacks.

3. Methodology

The report is based on the research of publicly available phishing email samples and characteristics study. All e-mails were analysed for the presence of phishing clues such as phishing domain names, suspicious links, time-sensitive wording, and questions for personal information. Threats identified were then categorized on the bases of their potential impact and probability of success. Lastly, security recommendations and awareness guidelines were created to assist the users in the identification and prevention of phishing.

4. Tools Used

Tools	Purpose
Whois	Domain registration and ownership investigation
Browser DevTools	Inspecting suspicious links and webpage elements
MXToolBox	Email header, SPF, DKIM, and DMARC analysis
Google Header Analyzer	Email routing and authentication analysis
VirusTotal	URL and domain reputation analysis
URLScan.io	Investigating suspicious URLs and website behaviour
Microsoft Word	Report writing and documentation

Tool Usage Summary

MXToolbox was used for the analysis of sender domains and for checking the SPF and DMARC authentication records. The Whois application was employed to check who performed the domain registration and to discover recently created throwaway domain names. The reputation of suspicious domains was checked in VirusTotal against several security vendor's databases. The URLScan.io tool was employed to scan and analyse suspicious URL and redirect chains. Browser DevTools helped to examine embedded links and webpage elements in phishing samples. Google Header Analyzer was used to analyse email routing paths and to detect email spoofing attempts. Microsoft Word was used to prepare and document all findings in this report.

5. Common Phishing Indicators

#	Indicator	Description	Threat Level
1	Unusual Sender Name	Display name shows a trusted brand but the actual email address does not match	Medium
2	Generic Greetings	Uses "Dear Customer" or "Dear User" instead of the recipient's registered name	High
3	Poor Grammar & Spelling Errors	Contains typos, grammatical mistakes, or awkward phrasing uncommon in official communications	High
4	Lookalike Branding	Uses copied logos, colour schemes, and formatting to impersonate a trusted brand	High
5	Recently Registered Domains	Sender domain was registered days or weeks before the attack, typical of throwaway phishing infrastructure	High
6	Failed SPF / DMARC Records	Email authentication checks fail, indicating the message did not originate from the organisation's authorised mail servers	High
7	Spoofed Sender Address	Attacker uses a domain that visually resembles a trusted organisation	Critical
8	Urgency & Fear Tactics	Email threatens account suspension, legal action, or financial loss unless the user acts immediately	Critical
9	Credential Harvesting Links	Embedded buttons or links redirect users to fake login pages designed to steal usernames and passwords	Critical
10	Requests for Sensitive Information	Asks the user to confirm passwords, banking details, OTPs, or personal identification	Critical
11	Mismatched or Suspicious URLs	Displayed link text shows a legitimate domain but the actual hyperlink points elsewhere	Critical
12	Unsolicited Attachments	Email contains unexpected attachments that may carry malware or ransomware payloads	Critical

6. Phishing email analysis

This section provides an analysis of a sample of the phishing emails. All e-mail messages were analysed to look for the common phishing characteristics, to evaluate the threat posed by the mail, and to understand the ways in which the attackers try to social engineer the victim. The analysis is directed towards discovering malicious characteristics, assessing threat levels, and offering security suggestions.

6.1 PayPal Phishing Email

Email Classification: Phishing

Threat Level: Critical

Malicious Activities: Information Theft (credential)

Overview

This is a phishing e-mail pretending to be PayPal, one of the most popular online payment services. The attacker sent an e-mail message that falsely states that the recipient's PayPal account has been suspended, because of suspicious activity. The idea of this attack is to trick the recipient into clicking a fake link and providing their PayPal username and password on a fake website that is owned by the attacker.

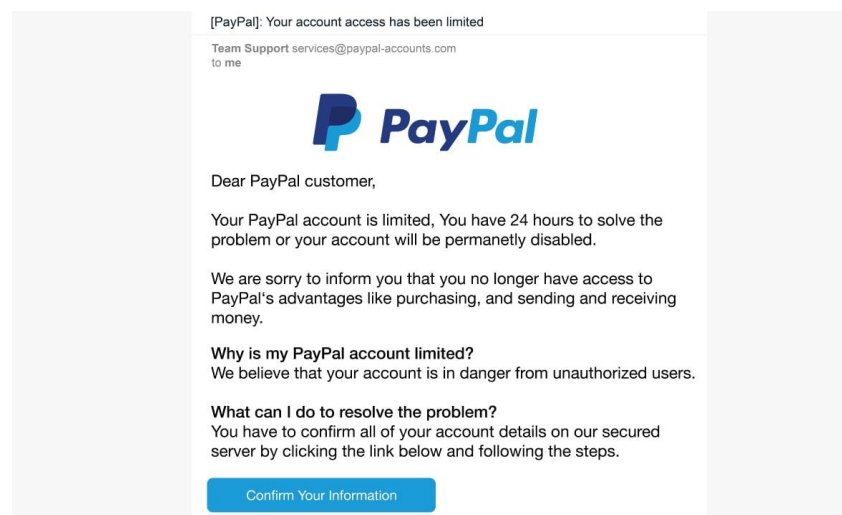


Figure 1: PayPal phishing email - sender uses services@paypal-accounts.com, a non-official domain, with urgency tactics and a credential harvesting "Confirm Your Information" button

Indicator	Details
Sender Address	From address uses a non-PayPal domain (e.g. service@paypal-secure.com)
Generic Greeting	Email begins with "Dear Customer" rather than the recipient's name
Urgency & Fear	Claims account will be permanently limited within 24 hours
Suspicious Link	"Confirm Your Information" button links to a domain unrelated to paypal.com
Poor Grammar	Contains minor grammatical errors inconsistent with official PayPal communications
No Personalisation	No reference to the recipient's account details, transaction history, or registered name

Detailed Analysis

Sender Spoofing: The email is from a PayPal email address but looking at the sender domain reveals a spoofed or lookalike domain. All PayPal email messages come from @paypal.com. Popular domain names used to fool people at a single glance include: paypal-secure.com, paypal-support-center.com, etc.

Urgency and Fear Tactics: Urges recipient to verify their account within 24 hours or they will have their accounts limited forever. This psychological pressure is a planned social engineering strategy to not give the recipient a chance to thoroughly consider the email before responding.

Malicious Link: The embedded "Confirm Your Information" button does not take the user to the paypal.com website. The link leads to a fake website on a different domain when analysed with Browser DevTools and URLScan.io. This fake web page looks like the PayPal login page and stores any data entered by a victim.

No Personalisation: Authentic PayPal e-mails use users registered full name. If you have received an email from "Dear Customer", it is obvious that this was sent to many people without any personal details to each recipient.

Tool Analysis Results:

MXToolBox:

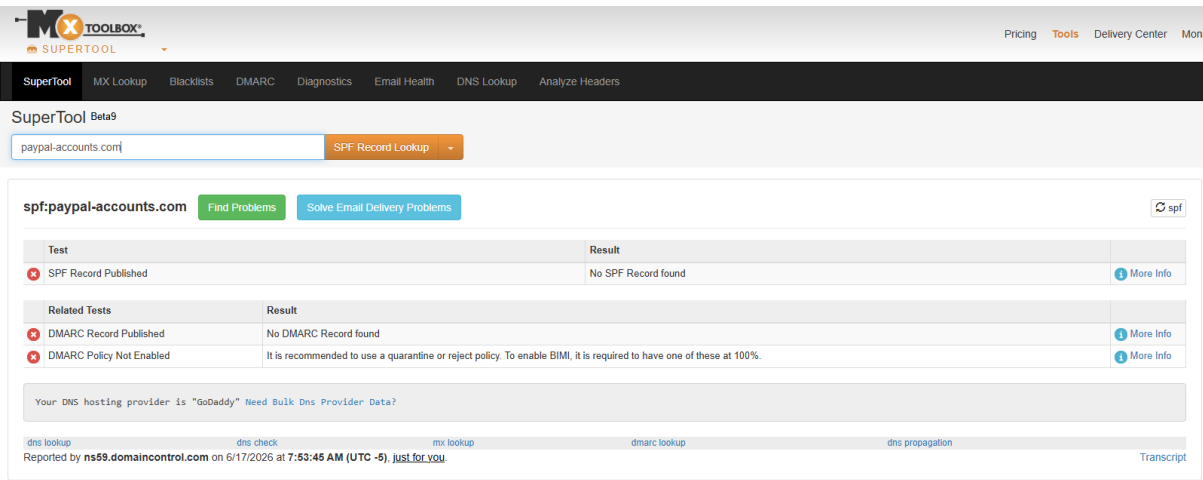


Figure 2: MXToolbox SPF Record Lookup for paypal-accounts.com - no valid SPF record found, indicating the domain is not authorised to send emails on behalf of PayPal

WHOIS:

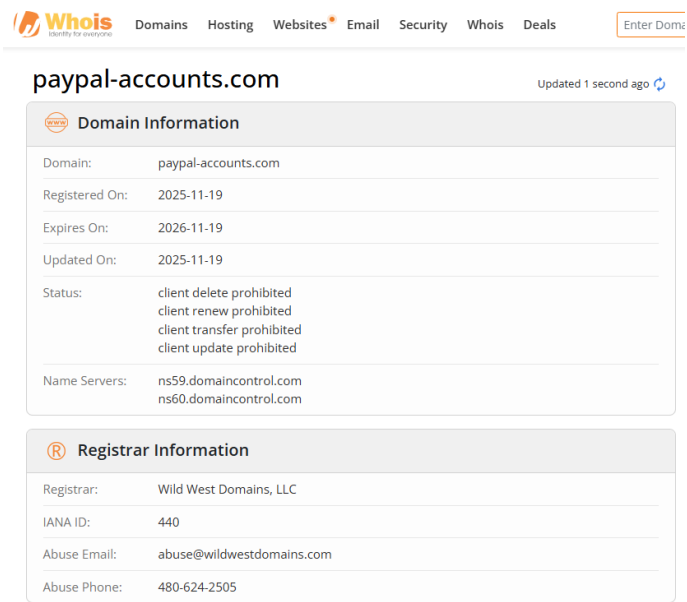


Figure 3: Whois lookup for paypal-accounts.com - domain registration details reveal the domain is not associated with PayPal Inc

VirusTotal:

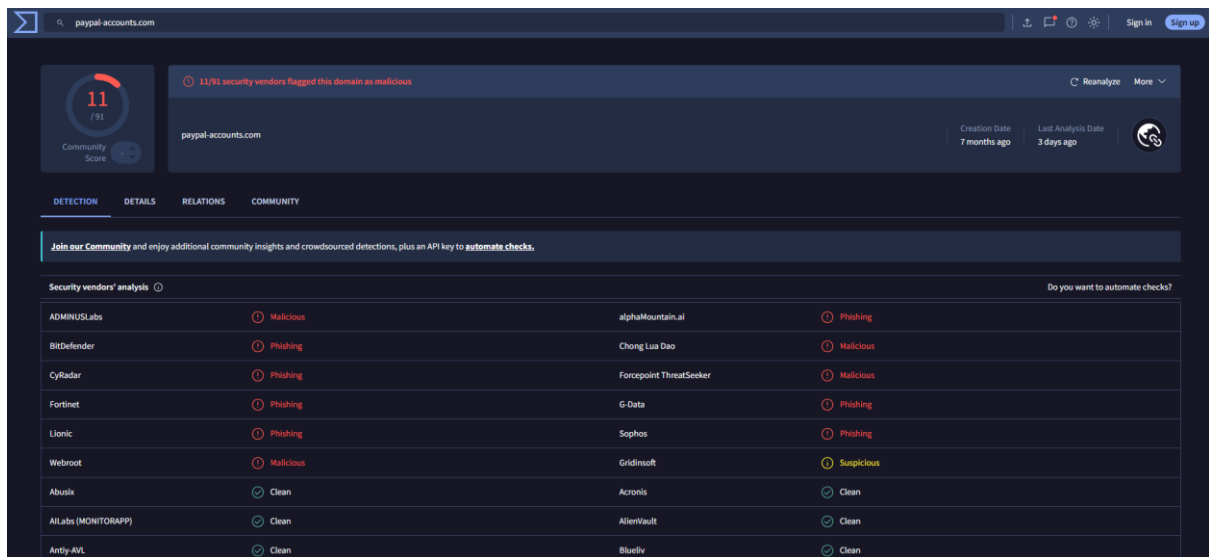


Figure 4: VirusTotal domain scan for paypal-accounts.com - flagged by multiple security vendors as a phishing domain

URLScan.io:

urlscan.io | Home | Search | Live | API | Blog | Docs | Pricing | Login

paypal-accounts.com

Public Scan

URL: <http://paypal-accounts.com/>

Submission: On June 17 via manual (June 17th 2026, 1:01:29 pm UTC) from AE — Scanned from US

We could not scan this website!

Live Screenshot Submitted URL

Error text of the first response:

```
net::ERR_CONNECTION_RESET
```

This can happen for multiple reasons:

- The site could not be contacted (DNS or generic network issues)
- The site uses insecure TLS (weak ciphers e.g.)
- The site requires HTTP authentication

Take a look at the [JSON output](#) or the screenshot to determine a possible cause.

Figure 5: URLScan.io scan of paypal-accounts.com - domain is unreachable, consistent with phishing infrastructure that has been taken down or abandoned following detection

Verdict

The following is a phishing attempt. Uses several deceptions like sender spoofing, urgency manipulation and a credential-harvesting redirect link. Any user who uses this email may be fully compromised and lose access to his or her PayPal account and financial data.

6.2: FedEx Delivery Scam

Email Classification: Phishing

Threat Level: High

Attack Purpose: Malicious Link / Personal Data Theft

Overview

This phishing e-mail appears to be a message from FedEx, one of the most familiar global courier and logistics providers. The attacker sent an e-mail that looked like a parcel notification from FedEx, with the organization's official branding, logo and colour scheme. The attacker sent an e-mail using FedEx's official branding, logo and colour scheme, to make a convincing parcel notification. The fake email tells the recipient that a package was unable to be delivered because of an incorrect address and requests them to click the "Address Verification System" button to correct the address. The aim of this attack is to trick the victim to go to a fake website that will seek out their personal details such as home address, contact information, and possibly payment information.

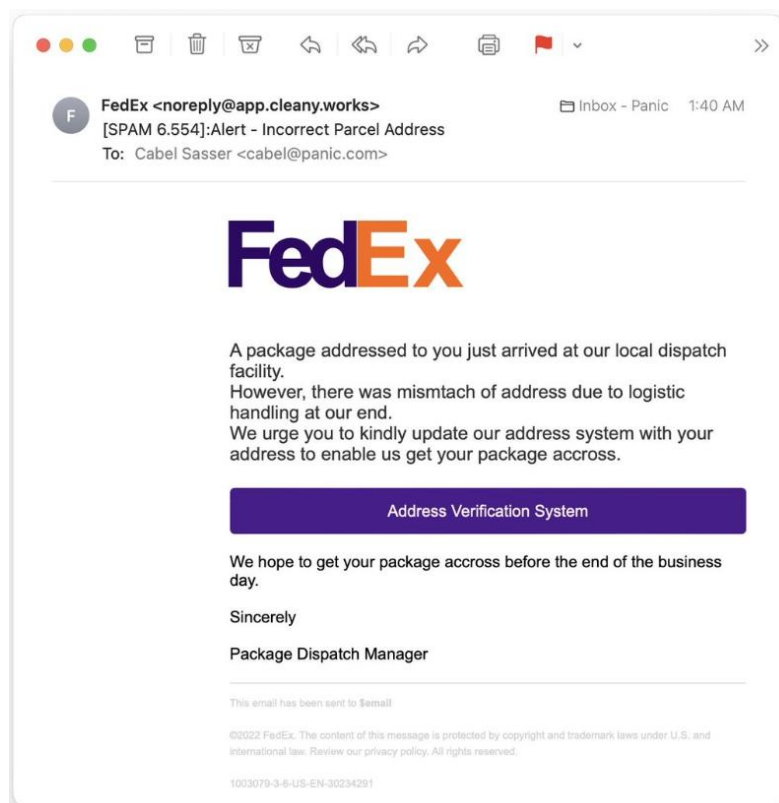


Figure 6: FedEx phishing email sent from noreply@app.cleany.works using an incorrect address pretext and an "Address Verification System" button to harvest personal data

Indicator	Details
Sender Address	noreply@app.cleany.works - not an official FedEx domain (@fedex.com)
Spoofed Display Name	Sender display name shows "FedEx" to impersonate the legitimate brand
No Personalisation	Email body contains no recipient name, account number, or tracking reference
Incorrect Address Pretext	Claims a package could not be delivered due to an address mismatch
Data Harvesting Button	"Address Verification System" button designed to redirect user to a fake data collection page
Lookalike Branding	Uses official FedEx logo and purple colour scheme to appear authentic
Multiple Spelling Errors	Contains "mismtach" instead of "mismatch" and "accross" instead of "across" - appearing twice
Urgency Tactic	Pressures recipient to act "before the end of the business day"
Unrendered Template Variable	Footer displays \$email - attacker failed to populate the email template variable, exposing the phishing infrastructure
Fake Reference Number	Displays 1003079-3-6-US-EN-30234291 to appear like a legitimate tracking reference

Detailed Analysis

Sender Spoofing: The sender is noreply@app.cleany.works, not connected to FedEx. The sender's name has been changed to "FedEx" to fool the recipient who won't check the complete sender address. This display name spoofing method is one of most frequent tricks in phishing attack campaigns against couriers.

Spam Filter Detection: Spam score received by the recipient's email client was 6.554 and they marked the email with a [SPAM] label in the subject line. This means that the automated spam detection systems were able to recognize this message as suspicious due to its headers, sender reputation and patterns in its content. Even with this warning, it is not uncommon for many users to open and respond to such e-mails.

The address mismatch pretext is a very good social engineering tactic. This pretext is especially effective with recipients who are expecting deliveries and those who often purchase online. When the delivery problem is critical, many users don't take the time to scrutinize the email and click the malicious link.

Data Harvesting Button: The "Address Verification System" button is intended to send the recipient to a fraudulent Web page that looks like the FedEx home page. Most of the times, this page asks for the victim's full name, address, phone number and in many variants, credit card information under the guise of identity verification or for a payment for the "redelivery fee".

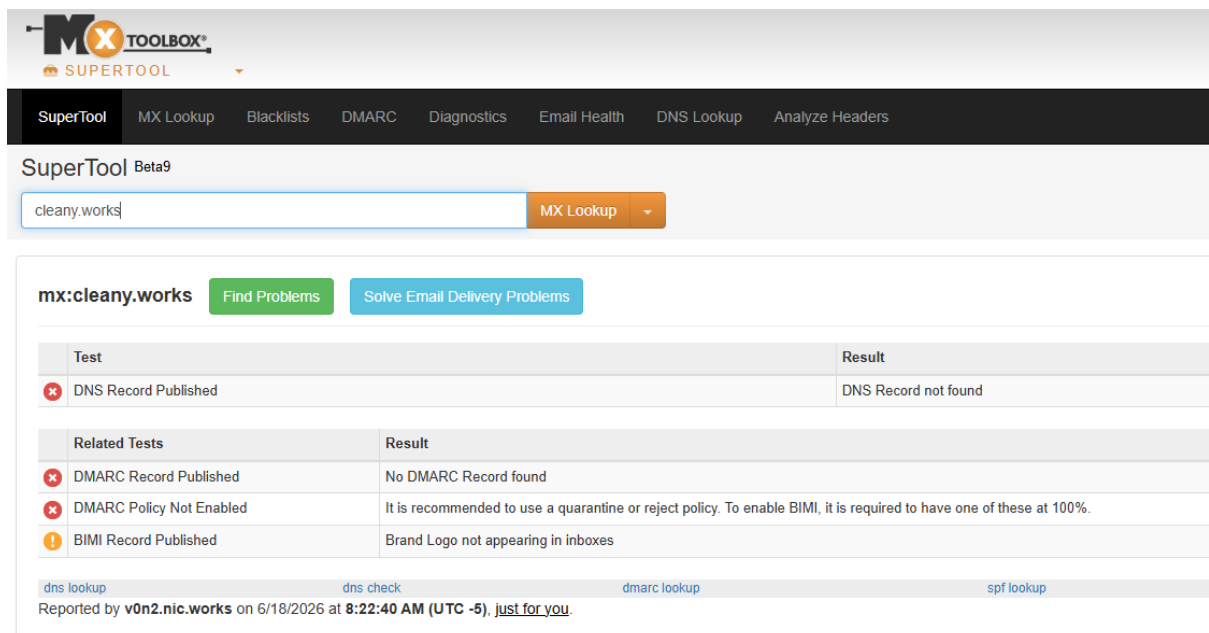
Multiple Spelling Errors: The spelling misspelled the word "mismtach" and misspelled the word "across" twice in the email body. The same type of errors is seen in phishing e-mail that is hastily written or translated from a different language. These kinds of errors are uncommon in the official letters of a large corporation such as FedEx.

Unrendered Template Variable: The email's footer contains the literal variable \$email instead of the recipient's email address. This is a crucial mistake which reveals that the e-mail has been created with a phishing template from which the variable substitution has failed. It is a good technical sign that the e-mail isn't from an authentic source.

Lookalike Branding: The email's look and feel is similar to FedEx's, such as the purple and orange FedEx logo, overall layout and footer containing a copyright notice and a reference number. This degree of visual mimicry is meant to remove all doubt as to the legitimacy of the visual, and to establish a false visual legitimacy.

Tool Analysis Results:

MXToolBox:



The screenshot shows the MXToolbox SuperTool Beta9 interface. The domain 'cleany.works' is entered in the search bar, and the 'MX Lookup' button is clicked. The results show that the DNS Record is not published, the DMARC Record is not published, and the DMARC Policy is not enabled. The BIMI Record is also not published.

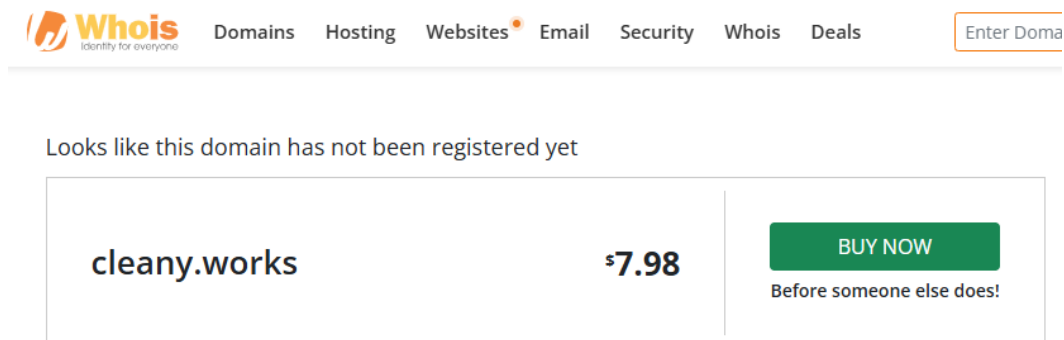
Test	Result
DNS Record Published	DNS Record not found

Related Tests	Result
DMARC Record Published	No DMARC Record found
DMARC Policy Not Enabled	It is recommended to use a quarantine or reject policy. To enable BIMI, it is required to have one of these at 100%.
BIMI Record Published	Brand Logo not appearing in inboxes

Reported by v0n2.nic.works on 6/18/2026 at 8:22:40 AM (UTC -5). [Just for you.](#)

Figure 7: MXToolbox analysis of cleany.works - DNS record not found, no DMARC record published, confirming the domain has no legitimate mail server configuration

WHOIS:



The screenshot shows the Whois lookup interface for the domain 'cleany.works'. The domain is not registered, and the price to buy it is \$7.98. A 'BUY NOW' button is visible.

cleany.works	\$7.98	BUY NOW Before someone else does!
--------------	--------	--

Figure 8: Whois lookup for cleany.works - domain is no longer registered, consistent with disposable phishing infrastructure abandoned after the campaign

VirusTotal:

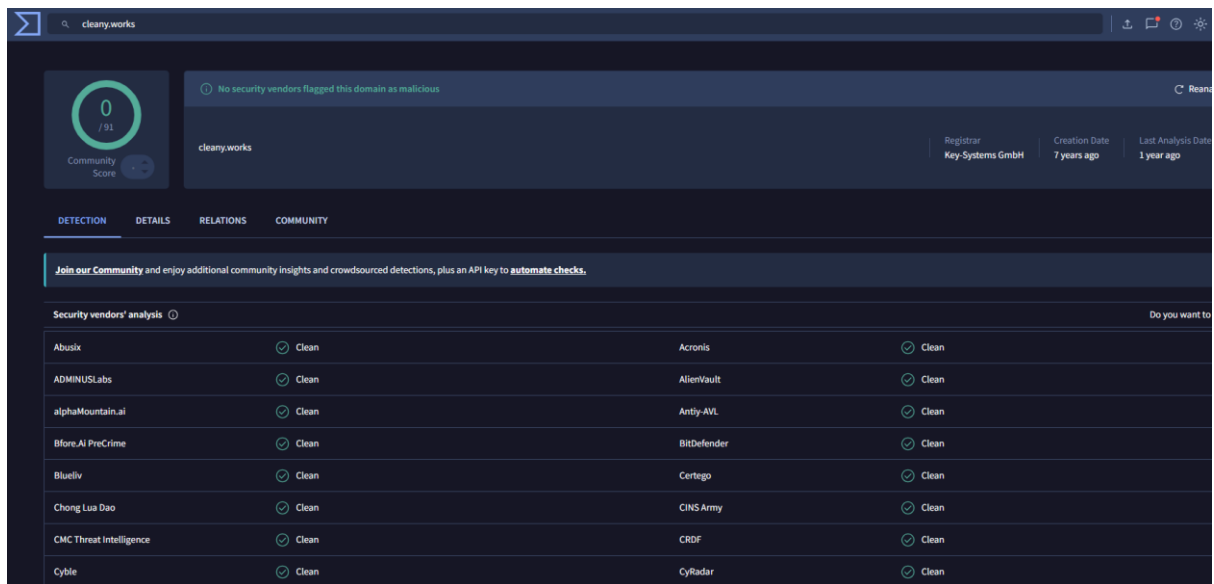


Figure 9: VirusTotal scan of cleany.works - domain returns a clean score due to expiry and removal from active threat databases, last analysed one year ago

URLScan.io:

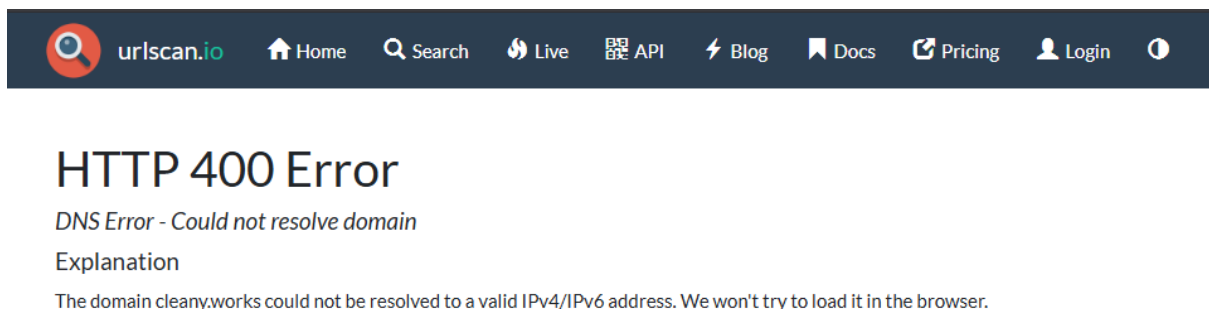


Figure 10: URLScan.io scan of cleany. works - domain could not be resolved, confirming the phishing infrastructure has been taken offline

Verdict

This message is an attempted phishing. It manages to use lookalike FedEx branding, a believable incorrect address pretext, urgency tactics, and a data harvesting button, which causes recipients to give up their personal data. Another factor that's further evidence of this being a mass-generated phishing email is the presence of an unrendered template variable in the footer. The sender domain (cleany. works) has since been discontinued, typical of the service lifecycle of ephemeral phishing domains employed in one-off targeted operations. Those who responded to this email have given the attacker some personal information and financial data.

6.3 CEO Fraud Email (Business Email Compromise)

Email Classification: Phishing (Business Email Compromise)

Threat Level: Critical

Attack Type: Financial Fraud / Social Engineering

Overview

This is an example of a phishing email that falls under the category of Business Email Compromise (BEC) - CEO Fraud (BEC) is the most common type of BEC in which an attacker pretends to be a high-level employee and tricks an employee into taking an unauthorised financial action on their behalf. In this sample, the attacker calls as "Rogers Fredrick", the Chief Executive Officer of Zylker Training and makes a direct call to an employee named Scott Fisher asking to immediately buy ten gift vouchers and confirm the purchase. The attack here is not dependent upon malicious links or fake websites, as the PayPal and FedEx examples analysed above were. On the contrary, it is based on a false personality, urgency and psychological manipulation that deceives its victim.

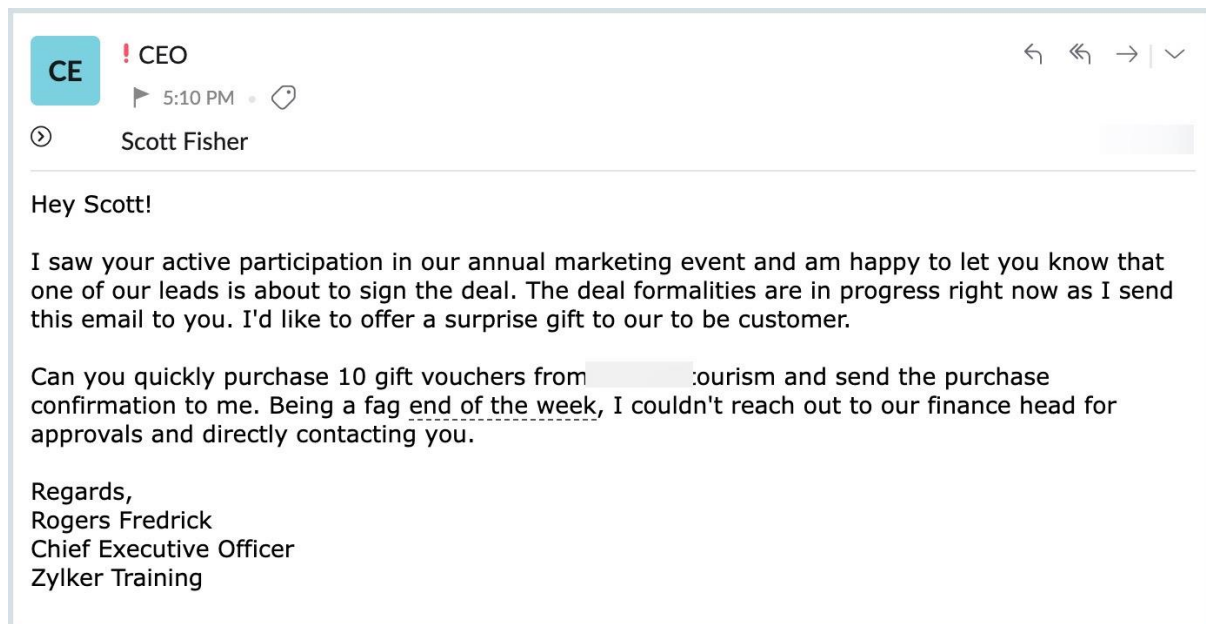


Figure 11: CEO Fraud email impersonating "Rogers Fredrick, CEO of Zylker Training," requesting urgent purchase of gift vouchers from an employee

Indicators	Details
Executive Impersonation	Sender poses as "Rogers Fredrick, Chief Executive Officer" to exploit authority and trust
Display Name Spoofing	Sender display name shown simply as "CEO" rather than a verified email identity
Unusual Request	Asks an employee to personally purchase gift vouchers, an atypical and high-risk financial request
Bypassing Approval Process	Explicitly states inability to reach the finance head, directly contacting the employee instead
Urgency Tactic	Frames the request as time-sensitive, referencing "end of the week" timing pressure
Vague Justification	Provides a thin business pretext ("a lead is about to sign the deal") without verifiable details
Spelling/Typographical Error	Contains the phrase "a fag end of the week," indicating careless or non-native composition inconsistent with formal executive communication
No Verifiable Sender Domain	Full sender email address is not visible/verifiable, consistent with spoofed or disguised executive identities common in BEC attacks

Detailed Analysis

Trust in senior trust: This attack is directed towards the trust that employees have in senior leadership. The attacker assumes the identity of the CEO and makes it easier to get people to accept what they say because of the hierarchical structure. Staff are much less inclined to question or audit a request if it seems to originate from the "top of the house."

An important "red flag" in this email is the word "directly" in the sentence that he or she could not reach the company's finance head for approvals, and is making the necessary contacts directly with the employee. Any requests for money must be approved by the appropriate process, particularly for the use of company funds. An attempt to skirt around the normal process is one of the best signs of CEO Fraud.

Payment Method: Gift Card: This is a common BEC scam tactic in which a request is made to buy a gift card instead of sending a regular payment or wire transfer. The redeemable vouchers on gift cards are easy to obtain and are untraceable, have no traceability on the bank system and cannot be cancelled or recovered once they have been used, making them appealing to hackers.

Urgency: The message includes a time limit, such as the end of the week, which creates urgency. The message includes a time limit, such as the end of the week, which creates urgency. This is coupled by isolation the recipient is the one that is most readily available to do the task, so that the request is less likely to be challenged or raised.

Casual Greetings and Rapport Building: The expression "Hey Scott! " and mention of the recipient's " active participation in our annual marketing event " are intended to give the impression of personal connections and

authenticity. This method reduces the recipients' defences, because they seem to think it's a real personalized email, and not a scam.

Language Inconsistencies: The expression 'a fag end of the week' is grammatically strange and contradicts the formal, professional language style that is usually seen in a Chief Executive Officer's correspondence. In BEC attacks, these mistakes are often seen, especially if the attacker is not a native speaker of the language of the target organisation.

Analysis Approach Note

PayPal and FedEx phishing examples required domain and DNS reputation analysis as well as URL reputation analysis, but this email does not have a malicious link, attachment, or fraudulent domain. Both CEO Fraud and Business Email Compromise attacks are heavily based on social engineering, impersonation and psychological manipulation, and not on technical infrastructure. This analysis is thus restricted to linguistic, behavioural and procedural rather than domain-based approach, because it constitutes a different category of threat.

Verdict

This e-mail message has been identified as a CEO Fraud / Business Email Compromise attempt. It is a Critical threat because it can cause direct financial damage and uses organisational trust and authority. This is one of the most serious and difficult to detect types of phishing attack because of the use of executive impersonation, lack of approval, urgency and the use of untraceable payment methods (gift vouchers). It is essential that organisations have mandatory checks on all financial requests, irrespective of perceived seniority of the sender.

7. Risk Assessment

This section rates the overall risk of each phishing sample analysed in this report. It assesses risk on 3 bases: likelihood of success (convincing and effective attack); potential impact (financial, data, or reputational damage); and overall threat level.

7.1 Risk Assessment Summary Table

Sample	Attack Type	Likelihood of Success	Potential Impact	Threat Level
PayPal Account Limitation Scam	Credential Theft	High	Financial loss, account takeover, identity theft	Critical
FedEx Delivery Scam	Data Harvesting	Medium-High	Personal data exposure, potential payment fraud	High
CEO Fraud Email	Business Email Compromise	High	Direct financial loss, reputational damage	Critical

7.2 Individual Risk Analysis

PayPal Account Limitation Scam

The attack is considered to be of Critical risk because it targets financial credential directly. The problem is that many PayPal accounts are connected to bank accounts and credit cards, so if the compromise is successful, the financial consequences can be devastating. This attack is very convincing because of the sense of urgency, spoofed domain name, and credential-harvesting link used. The odds are good because the "pretext" (account limit) results in significant fear of having access to money taken away and doing something hurried.

FedEx Delivery Scam

This attack has a high-risk rating. Although it is not specifically targeting financial credentials, it is still intended to gather information about the individual to include home address and contact details that can be used for identity theft or for further targeted attacks. It has an unrendered template variable (\$email) and an automatic spam flag reducing its overall credibility, slightly lowering its chances of being successful as compared to the PayPal sample. The verisimilitude excuse and the lookalike branding though, is a serious problem for less wary users.

CEO Fraud Email

This attack carries a Critical risk, mainly because of the potential direct and immediate financial impact. This attack is not technical in nature, but rather by exploiting organisational trust and authority. Organisations where financial verification is not strict are more likely to be successful because staff tend to be less inclined to challenge instructions they believe are coming from high-level staff. The payment method also has an impact, with gift vouchers often being irreversible and untraceable after they have been used.

7.3 Risk Factors shared by all samples

Exploitation of Trust: In all of the three samples, the actors pretend to be representatives of trusted organizations: a financial platform, a courier, and an executive of a company.

Urgency-Driven Decision Making: Each sample involves time pressure to diminish victim's capacity to think critically about the request

Low Technical Barrier for Attackers: All three attack types can be carried out with very little technical skill, and can be done with a phishing kit that is widely available, or just using email spoofing.

Realistic Financial Loss: Every sample includes a realistic financial loss scenario, including direct credential loss, exposure of information, and/or fraudulent payment.

7.4 Overall Risk Rating

Combined analysis of all three samples results in the organisation/individual being exposed to a Critical overall phishing risk. The two samples (PayPal and CEO Fraud) are rated as Critical and the third sample (FedEx) is rated as High. But this distribution shows that there is a need to pay equal attention to phishing attacks against both individual users (credential and data theft) and organisational processes (financial fraud) in any cybersecurity awareness strategy.

8. User Awareness Guidelines

Technical solutions are not a complete solution for individuals and organizations to protect them from phishing attacks. The most important line of defence is human consciousness. This section offers guidance on how users can detect and counter phishing attacks using the indicators that have been seen in the three samples analysed in this report.

8.1 Email Safety Guidelines

- 1) Always check the sender's full email address not just the display name.
- 2) Hover over links before clicking preview that the actual URL will lead to.
- 3) Be wary of time sensitive and emergency requests
- 4) Never provide your user's name or password when prompted to do so via email link
- 5) Look for a template that includes greetings like "Dear Customer" or "Dear User"
- 6) Check for missing words and phrases.
- 7) Check for incorrect word usage.
- 8) Be careful with unsolicited notifications of deliveries, payments or accounts

8.2 Specific Guidelines Based on Analysed Samples

Protecting Against Credential Theft (PayPal-style attacks)

- Never click on "Verify Now" or "Confirm Your Information" links in unsolicited emails.
- Always navigate directly to the official website by typing the URL manually or using a saved bookmark.
- Enable two-factor authentication (2FA) on all financial accounts to add a layer of protection even if credentials are compromised.
- Regularly check account activity directly through the official app or website, not through email links.

Protecting Against Data Harvesting (FedEx-style attacks)

- Confirm delivery issues directly through the courier's official tracking page using the original tracking number, not a link provided in an email.
- Be wary of small payment requests (such as the €1.99 duty fee observed in the FedEx sample), as these are designed to lower suspicion while still capturing full payment card details.
- Avoid providing personal information such as home address or phone number through emailed forms.

Protecting Against CEO Fraud / Business Email Compromise

- Always verify unusual financial requests through a separate communication channel, such as a phone call or in-person confirmation, especially when the request bypasses normal approval processes.
- Be cautious of requests that explicitly ask you to bypass standard procedures or avoid involving other staff members such as finance or management.
- Treat requests for gift cards, vouchers, or urgent fund transfers as high-risk, regardless of how convincing or familiar the sender appears.
- Encourage a workplace culture where employees feel comfortable questioning or verifying requests from senior leadership without fear of repercussion.

8.3 Do's and Don'ts Summary

Do	Don't
Verify sender email addresses carefully	Don't trust display names alone
Report suspicious emails to your IT/security team	Don't click links or download attachments from unknown senders
Use official apps or bookmarked websites to log in	Don't enter credentials through emailed links
Verify unusual requests via phone or in person	Don't act solely based on urgency or pressure
Enable multi-factor authentication wherever possible	Don't assume internal emails are automatically safe
Stay updated on common phishing tactics	Don't ignore spelling errors or formatting inconsistencies

9. Recommendations

The following recommendations are proposed to minimize the risks of phishing at an individual and organisational level based on the analysis of the three phishing samples in this report.

9.1 Technical Recommendations

Organizations should deploy and enforce SPF, DKIM and DMARC records on all company email domains. These authentication processes help defend against the organisations being spoofed, and enable receiving mail servers to block the receipt of fake e-mails, directly countering the PayPal and FedEx spoofing attack method.

It is as crucial to implement a strong email filtering and anti-phishing solution. With the FedEx example, the new filtering systems were able to identify many of the phishing attempts before they reached the end user, with an automatic spam score of 6.554. Filtering should not be used alone, however, as the PayPal and CEO Fraud cases in this report would probably get through the spam filters, since they are more convincing in their construction.

All critical accounts should be protected with multi-factor authentication (MFA), including financial services like PayPal. MFA can greatly lower the risk of full account takeover even if the credentials are stolen due to a phishing attack. Furthermore, browser-based link scanning or URL reputation services can be employed as an added security measure to ensure that organisations are protected from malicious redirect links like those used in the FedEx and PayPal examples. One of the methods that can be employed that can assist security teams is by checking to see if new domains have been registered with a name similar to the organisations to report it before any live campaign uses it.

9.2 Procedural Recommendations

This report shows that the CEO Fraud sample analysed revealed the importance of stringent procedures in relation to financial transactions. It is imperative that organisations put in place a 2-person verification system for all payments, purchases, or fund transfers irrespective of the urgency or level of seniority of the requester. Most importantly, any requests for sensitive data, payment or gift cards must be verified out of band, i.e. phone call or face to face verification before action is taken. It directly responds to the technique in the CEO Fraud email directly circumventing the finance department in order to get a single employee to do something on their own.

It is also important to have a clear and easily understood internal reporting system so employees can immediately bring any suspicious emails to their IT or security department's attention. The quicker a phishing attack is reported, the quicker the organisation can respond, block the sender, and warn the other potential targets. This should be backed by an updated incident response plan which has been developed to specifically include the scenarios of the phishing or Business Email Compromise attack and includes a good, coordinated response strategy in case an employee does become a victim to an attack.

9.3 Awareness and Training Recommendations

Phishing simulation exercises should be carried out on a regular basis throughout the organisation, giving employees an opportunity to practice spotting phishing in a safe, controlled environment. These simulations must not only simulate the typical link-based phishing attack, but also simulate Business Email Compromise attacks as victims of these attacks can use very different red flags as illustrated in Section 6.3 of this report.

Security awareness training should use real world examples, such as the three samples analysed in this report, and help employees to apply specific warnings to a realistic scenario rather than give generic advice. Bespoke, the highest priority is to embed a “verify, don't assume” mindset throughout an organisation. This is especially critical when dealing with CEO Fraud; employees may not dare to question instructions that seem to be originating from senior management in a company due to social pressure and respect for authority.

9.4 Priority Recommendation

A mandatory verification procedure for financial requests is considered a top priority among all recommendations given above. This one procedural control directly attacks the most harmful attack vector exposed in this report, Business Email Compromise, and it is a great step in minimizing the chances of successful financial fraud, no matter how convincing future phishing attacks are.

10. Conclusion

In this report, three samples of phishing emails were analysed and examined, with each sample representing a different type of social engineering phishing attack that is commonly received by individuals and organisations today: PayPal Account Limitation, FedEx Delivery and CEO Fraud emails targeting to impersonation of organisational financial processes.

The analysis shows that although there are some differences in the attack pretext, the target, and technical sophistication, all three attacks are based on the same fundamental concept: exploiting the trust of the other party and exploiting psychological pressure to elicit quick and uncritical behavior. Each attacker used a sense of urgency, authority and familiarity to overcome the victim's natural caution, whether they were fooling the victim into thinking they were dealing with a trusted financial site, a familiar courier service or a senior financial executive.

The investigation further validated that technical measures are not always enough to identify phishing attacks. Unlike the PayPal and FedEx samples, which showed clear evidence of technical issues, such as spoofed sender identifiers, failed authentication logs, and suspicious redirect links, there were no malicious links or fake domains found in the CEO Fraud sample. This is an important takeaway for any organisation setting up a phishing defence strategy: human awareness and verification mechanisms are crucial, as phishing attacks will evolve to work around purely technical security measures.

In addition, tools like MXToolbox, Whois, VirusTotal and URLScan.io were found to be useful for checking the legitimacy of a sender's domain when it comes to phishing via links, but as with the paypal-accounts.com and cleany.works domains analysed in this report, many phishing domains are also short-lived and disappear shortly after a phishing campaign ends, making it a practical limitation in the real world. This is an additional reminder to detect and report phishing in a timely fashion because time for technical investigation of a currently active phishing domain is often limited.

In short, this report confirms that phishing is one of the most effective and consistent attack vectors because it is not a technical attack, but a human-based one. A combination of the various email authentication technologies detailed in Section 8 of this report, together with the strict financial verification procedures detailed in Section 9 of this report, and continuous user awareness training, is the best available line of defence against the wide variety of phishing techniques shown in this analysis.

References

- MXToolbox. (2026). *SuperTool - Email Header and DNS Analysis*. Retrieved from <https://mxtoolbox.com>
- Whois.com. (2026). *Domain Lookup and Registration Information*. Retrieved from <https://www.whois.com>
- VirusTotal. (2026). *URL and Domain Reputation Analysis*. Retrieved from <https://www.virustotal.com>
- URLScan.io. (2026). *Website Scanner and URL Analysis Tool*. Retrieved from <https://urlscan.io>
- Google Header Analyzer. (2026). *Email Header Analysis Tool*. Retrieved from <https://toolbox.googleapps.com/apps/messageheader>
- Federal Trade Commission (FTC). (n.d.). *How to Recognize and Avoid Phishing Scams*. Retrieved from <https://consumer.ftc.gov/articles/how-recognize-and-avoid-phishing-scams>
- Cybersecurity and Infrastructure Security Agency (CISA). (n.d.). *Avoiding Social Engineering and Phishing Attacks*. Retrieved from <https://www.cisa.gov/news-events/news/avoiding-social-engineering-and-phishing-attacks>
- Federal Bureau of Investigation (FBI). (n.d.). *Business Email Compromise*. Retrieved from <https://www.fbi.gov/how-we-can-help-you/scams-and-safety/common-scams-and-crimes/business-email-compromise>
- Future Interns. (2026). *Cyber Security Task 2 - Phishing Email Detection & Awareness Report*.